Report Creazione di una regola Firewall

Consegna S3L5

Obiettivo

L'obiettivo dell'esercizio era creare una regola firewall che bloccasse l'accesso alla DVWA (su Metasploitable) dalla macchina Kali Linux e ne impedisse di conseguenza lo scan. Un requisito fondamentale della consegna era che le macchine Kali e Metasploitable fossero su reti diverse: per questo ho aggiunto una nuova interfaccia di rete a pfSense, in modo tale da gestire una ulteriore rete.

Pre-requisiti: — pfSense MV

Il prerequisito per poter svolgere la consegna era l'installazione di pfSense in una macchina virtuale. Nel mio caso ho utilizzato VirtualBox . L'installazione è stata abbastanza lineare e non ho riscontrato problemi particolari: Prima di poter configurare le interfacce di rete, ho dovuto spegnere la VM per poter aggiungere le schede di rete necessarie direttamente dalle impostazioni di VirtualBox. pfSense ha bisogno di almeno due interfacce (una WAN e una LAN), ma visto che la consegna richiede due reti separate, ne ho configurate tre in totale.

Pre-requisiti: — pfSense [Schede di rete]

In questa fase ho configurato le schede di rete. Dalle impostazioni della VM in VirtualBox ho abilitato tre schede di rete e le ho configurate in questo modo:

Interfaccia pfSense	Modalità VirtualBox	Scopo
em0 (WAN)	NAT	Connessione verso l'esterno (upstream)
em1 (LAN)	Scheda con Bridge	Rete interna di Kali Linux — 192.168.0.0/24
em2 (OPT1)	Scheda con Bridge	Rete interna di Metasploitable — 192.168.4.0/24

Ho messo la WAN in NAT così che pfSense avesse accesso a internet senza doversi preoccupare della rete fisica, mentre per la LAN e la OPT1 ho usato la modalità "Scheda con Bridge" di VirtualBox, in modo che le due interfacce fossero collegate direttamente alla rete. In questo modo Kali e Metasploitable possono

comunicare con pfSense come se fossero tutte e tre macchine reali connesse alla stessa rete, ma il traffico tra loro deve obbligatoriamente passare da pfSense.

Dopo aver aggiunto le schede dalla VM, ho riacceso pfSense e dalla console ho assegnato gli indirizzi IP alle interfacce: em1 (LAN) con 192.168.0.100/24 e em2 (OPT1) con 192.168.4.1/24. La em0 (WAN) invece l'ho lasciata in DHCP, così da ricevere automaticamente l'indirizzo dalla rete di VirtualBox.

Topologia di Rete creata

Nella tabella qui sotto riassumo tutti gli indirizzi IP assegnati, la rete di appartenenza e il gateway di ciascuna macchina:

Macchina	IP Address	Rete	Gateway verso pfSense
pfSense (LAN)	192.168.0.100	192.168.0.0/24	— (è il gateway)
pfSense (OPT1)	192.168.4.1	192.168.4.0/24	— (è il gateway)
Kali Linux	192.168.0.54	LAN	192.168.0.100
Metasploitable	192.168.4.10	OPT1	192.168.4.1

Un dettaglio importante emerso durante la configurazione: sia Kali che Metasploitable avevano inizialmente il gateway impostato su indirizzi errati assegnati dai rispettivi DHCP, anziché sugli IP delle interfacce pfSense. È stato necessario correggere manualmente gli indirizzi e le route su entrambe le macchine per permettere la comunicazione inter-rete attraverso pfSense.

Accesso alla WebGUI di pfSense

Per poter accedere alla WebGUI di pfSense ho assegnato a Kali un indirizzo IP della stessa rete LAN di pfSense (192.168.0.0/24), con default gateway l'indirizzo IP di pfSense (192.168.0.100), utilizzando i seguenti comandi e rimuovendo quelli che la macchina Kali aveva di default appena accesa:

- *sudo ip addr del **indirizzo_di_kali il mio era (192.168.1.1**/24) dev eth0*
- *sudo ip addr add 192.168.0.54/24 dev eth0*
- *sudo route del default*
- *sudo route add default gw 192.168.0.100*

Riuscendo così ad entrare nella WebGUI di pfSense digitando nel browser l'indirizzo 192.168.0.100.

Questo step l'ho emulato anche per Metasploitable, assegnandole l'indirizzo 192.168.4.10 con gateway 192.168.4.1.

Creazione delle regole del Firewall

Da questo momento in poi sono riuscito a procedere con la parte centrale di questa esercitazione: la creazione di una regola firewall che bloccasse il traffico da Kali verso la DVWA su Metasploitable.

Per poter configurare le regole in pfSense, sono dovuto andare sulla sezione "Firewall" → Rules. Ho cominciato a configurare le regole nel seguente ordine:

Un aspetto importante che ho notato subito è che pfSense di default, quando aggiungi una nuova interfaccia come OPT1, non applica nessuna regola che permetta al traffico di passare. Di conseguenza all'inizio le due reti non riuscivano a comunicare: ogni pacchetto in arrivo su OPT1 veniva scartato automaticamente. Per far partire la comunicazione ho quindi dovuto creare prima le regole Pass che autorizzassero il traffico tra LAN e OPT1.

La prima regola che ho impostato, tralasciando quelle che pfSense inserisce di default come la "Default allow LAN to any rule" che permette tutto il traffico proveniente dalla rete LAN verso qualsiasi destinazione, è stata la regola che permettesse la comunicazione tra le due reti, quindi da LAN a OPT1. Questa regola dice che: *qualsiasi traffico che arriva dalla rete 192.168.0.0/24 e sia diretto verso 192.168.4.0/24, fallo passare.*

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	4/44 KiB	*	*	*	LAN Address	80	*	*		Anti-Lockout Rule	
✗	0/0 B	IPv4 TCP	192.168.0.54/24	*	192.168.4.10/24	80 (HTTP)	*	none			
✓	0/0 B	IPv4 *	192.168.0.0/24	*	192.168.4.0/24	*	*	none		Defoult	
✓	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	

La seconda regola è stata invece di impostare su OPT1 la stessa regola di default della LAN: "Default allow OPT1 to any rule".

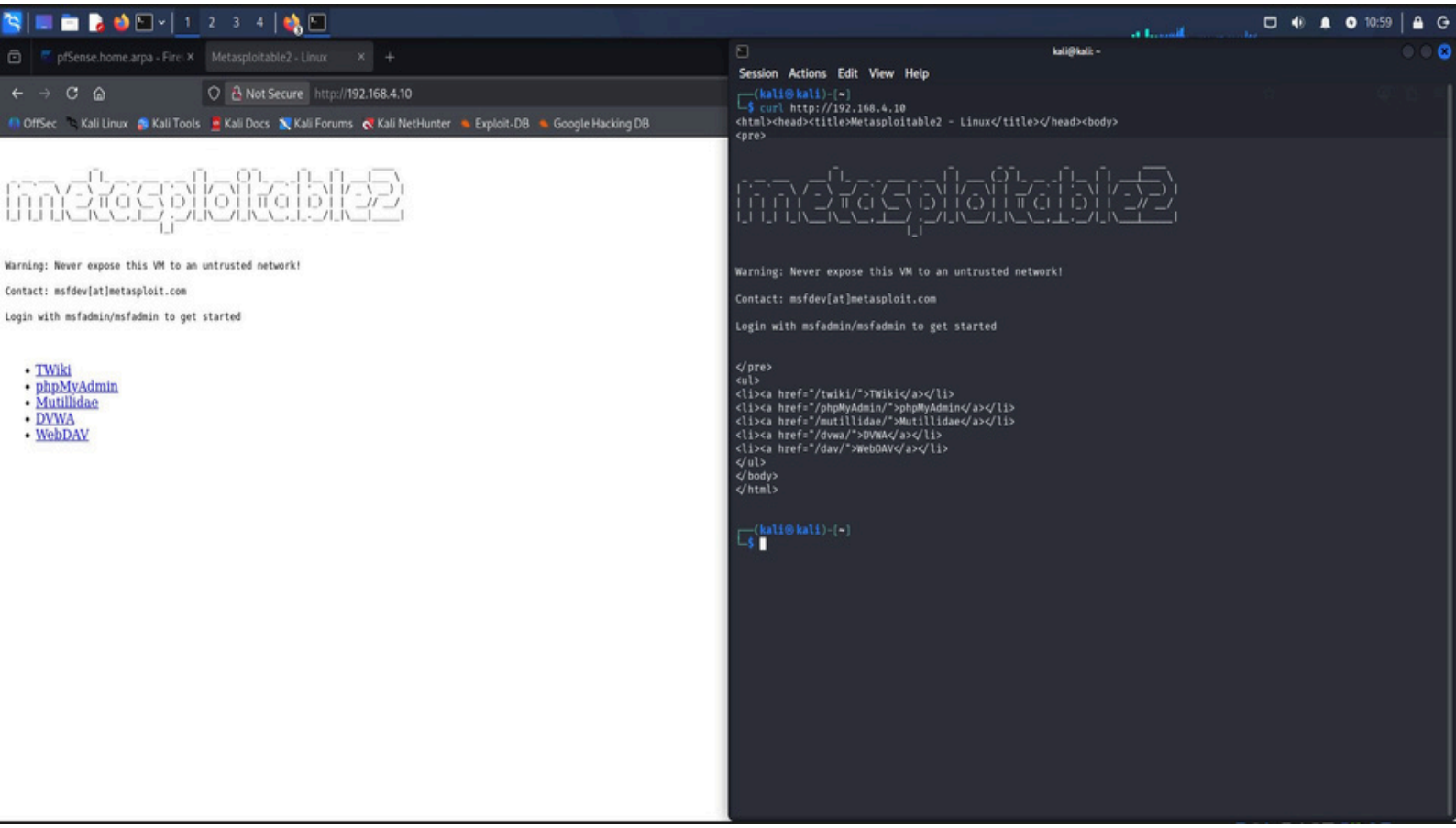
La terza regola, sempre su OPT1, è stata la stessa regola che ho impostato su LAN ma invertendo la sorgente e la destinazione: in questo modo ho permesso la comunicazione da OPT1 a LAN.

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	0/0 B	IPv4 *	192.168.4.0/24	*	192.168.0.0/24	*	*	none			
✓	0/0 B	IPv4 *	*	*	*	*	*	none			

Grazie a queste regole impostate, sono riuscito a pingare da Metasploitable a Kali Linux e viceversa, confermando che le due reti ora comunicavano correttamente attraverso pfSense:

Ho fatto anche una verifica aggiuntiva da Kali verso Metasploitable sulla porta 80 inserendo sulla ricerca http://192.168.4.10, e la pagina della DVWA era raggiungibile senza problemi (questo è importante per capire la differenza rispetto a dopo l'applicazione del blocco):



Creazione delle regole:

In questa fase sono andato a impostare la regola che mi permettesse di applicare il blocco richiesto dalla consegna, quindi il traffico da Kali verso DVWA su Metasploitable.

Per impostare la seguente regola sono andato su Rules → LAN. Da qui ho cominciato a impostare la regola che serviva per applicare il blocco:

- per prima cosa ho impostato come azione **"Block"**, che funge da scarto del pacchetto
- su **interface** ho impostato ovviamente **LAN**, ovvero l'interfaccia da cui arriva il traffico di Kali
- come **address family** gli indirizzi **IPv4**
- come **protocollo** ho lasciato **TCP**, perché il blocco è sul protocollo HTTP che viaggia su TCP
- come **sorgente** ho impostato Network con l'indirizzo **192.168.0.54/24**, ovvero l'indirizzo IP di Kali
- come **destinazione** Network con l'indirizzo **192.168.4.10/24**, ovvero l'indirizzo IP di Meta
- sulla **porta di destinazione** ho impostato solo quella di HTTP, ovvero la **(80)**
- aggiungendo poi come descrizione una frase che mi permettesse di riconoscere la stessa.

Grazie a questa regola abbiamo detto al firewall: *Se Kali (avente come indirizzo IP 192.168.0.54) tenta di raggiungere Metasploitable (avente come indirizzo IP 192.168.4.10) sulla porta 80 via TCP, scarta il pacchetto senza dire nulla.*

Per poter confermare tutte le regole impostate sulla GUI ho cliccato Apply Changes per rendere effettive così tutte le modifiche effettuate.

Verifica del Funzionamento di tutta la configurazione

Da qui in avanti ho cominciato a verificare il funzionamento di tutte le configurazioni effettuate.

Il primo test effettuato è stato quello di tentare una connessione HTTP alla porta 80 di Meta usando curl. Il risultato è stato quello atteso: dopo circa 2 minuti ho ottenuto lo stato di timeout, andando a confermare che pfSense sta scartando i pacchetti (regola di blocco attiva).

```
┌──(kali㉿kali)-[~]
└─$ curl http://192.168.4.10/DVWA

curl: (28) Failed to connect to 192.168.4.10 port 80 after 134729 ms: Could not connect to server
```

Secondo Test

Il secondo test che ho effettuato è stato la scansione della porta 80 su Meta. Tramite il comando:

```
nmap -p 80 192.168.4.10
```

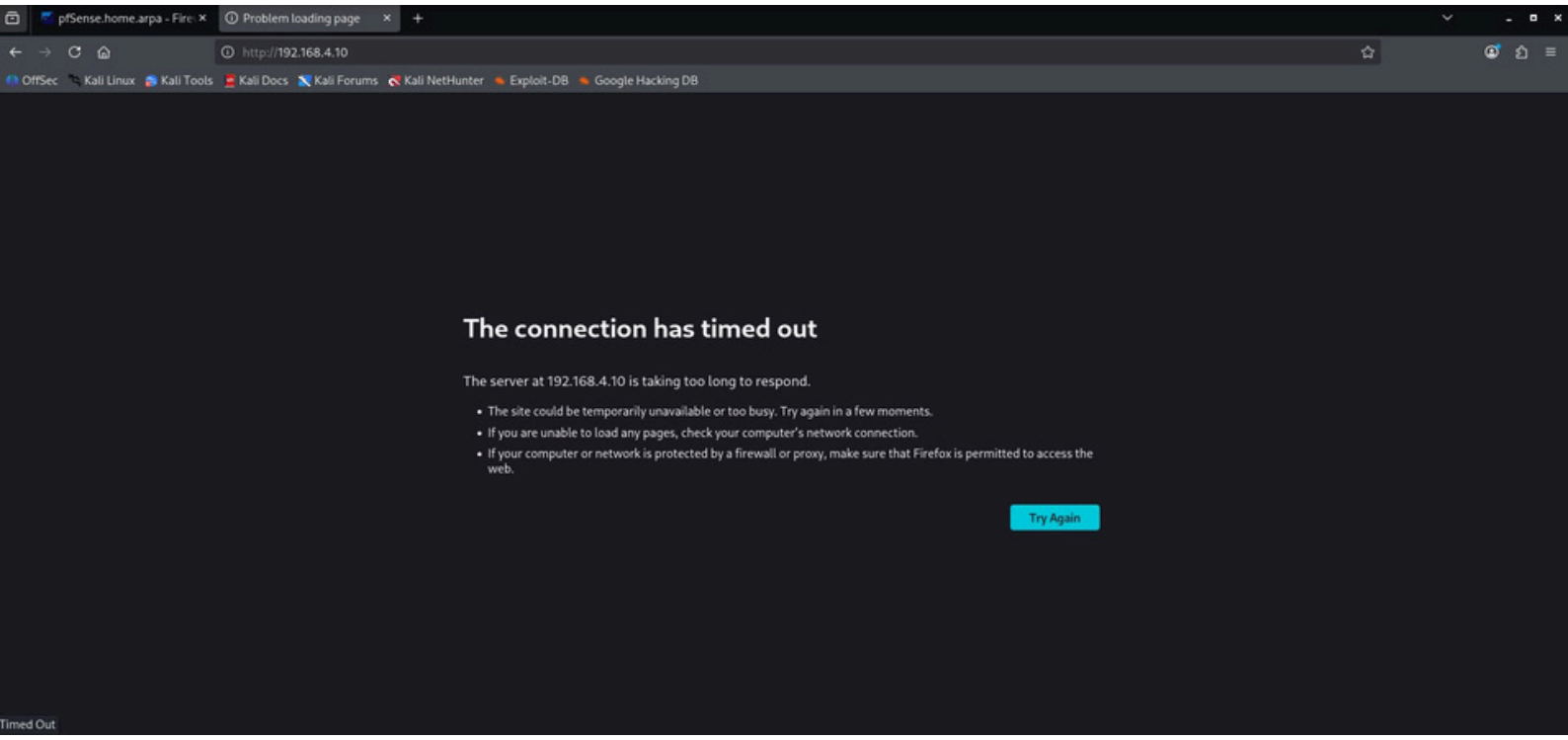
ho ottenuto come risultato anche qui quello atteso, ovvero che nmap, riportando la porta 80, la rileva filtrata "filtered", quindi sta dicendo in modo esplicito la presenza di un firewall che sta bloccando attivamente i pacchetti verso la porta che abbiamo impostato prima, ovvero la 80.

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 80 192.168.4.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-24 08:19 -0400
Nmap scan report for 192.168.4.10
Host is up (0.010s latency).

PORT    STATE    SERVICE
80/tcp filtered http

Nmap done: 1 IP address (1 host up) scanned in 3.26 seconds
```

Come ulteriore conferma ho provato anche dal browser Firefox su Kali ad aprire l'indirizzo della DVWA: dopo un po' di attesa Firefox ha mostrato la classica pagina di errore "The connection has timed out", a conferma che pfSense sta scartando silenziosamente i pacchetti:



Conclusioni

Grazie a questa esercitazione sono riuscito a capire il funzionamento di un firewall (pfSense) e come funzionano le regole di un firewall.

Rispetto a quello che mi aspettavo all'inizio, la cosa che mi ha sorpreso di più è stato scoprire che pfSense non fa passare il traffico di una nuova interfaccia finché non gli dai regole esplicite: questo mi ha costretto a capire bene la logica delle regole Pass prima ancora di mettere quella di blocco richiesta dalla consegna.

In sintesi:

- pfSense gestisce il routing tra le due reti separate **192.168.0.0/24** (LAN — Kali) e **192.168.4.0/24** (OPT1 — Metasploitable)
- le regole del firewall garantiscono che solo il traffico autorizzato riesca a transitare tra di loro
- la regola di blocco impedisce in modo mirato a Kali di raggiungere la DVWA sulla porta 80, senza però impedire il resto della comunicazione tra le due reti
- i test con curl (timeout) e nmap ("filtered") hanno confermato il corretto funzionamento del blocco